



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Gitea Code Injection Exploitation Priority - 2026-08-26 Daily Update

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-08-26
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | Gitea Code Injection Exploitation Priority - 2026-08-26 Daily Update - CVE / Vulnerability Threat Intelligence Report

Published: 2026-08-26 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
 - 9.1. Detection Logic Summary
10. Threat Hunting
 - 10.1. Hunt Hypothesis
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

Gitea Code Injection Exploitation Priority - 2026-08-26 Daily Update

1. Executive Summary

CISA added CVE-2026-60004 to KEV on 2026-08-25. Gitea is a high-value developer-platform target because compromise can expose source code, deployment automation, secrets, and release workflows.

Lost Boys Cyber selected this vulnerability for the 2026-08-26 Top 2 because it is newly added to KEV and affects developer infrastructure that can become a supply-chain pivot. The report is a defender-prioritization product, not exploit-development guidance.

2. Vulnerability Metadata

Field	Value
CVE	CVE-2026-60004
Vendor / Project	Gitea
Product / Component	Gitea
CISA KEV Date Added	2026-08-25
Federal Remediation Due Date / Priority Window	Immediate risk-based remediation under CISA BOD 26-04
Exploitation Status	Known exploited in the wild per CISA KEV signal
Primary Defender Question	Which exposed or business-critical instances remain unpatched today?

3. Source Review & Confidence

Source	Contribution	Confidence
CISA Known Exploited Vulnerabilities Catalog	Primary exploited-vulnerability prioritization for CVE-2026-60004.	High
Gitea security advisory GHSA-rcr6-4jqh-j84m	Vendor/security-advisory context for affected product and mitigation ownership.	Medium-High
NVD CVE-2026-60004	CVE/NVD or supporting catalog record for public metadata validation.	Medium

Confidence is highest for KEV-level urgency and public product identity. Asset-specific impact must be confirmed against local inventory and vendor fixed-version guidance before emergency change windows are approved.

4. Vulnerability Details

Public reporting identifies CVE-2026-60004 as affecting Gitea. The operational risk is that attacker interaction with reachable application or administrative functionality can lead to code execution, access-control bypass, command execution, or other post-compromise outcomes depending on deployment context. This report intentionally avoids unverified exploit primitives and focuses on exposure reduction and detection.

5. Attack Scenarios

Scenario	Defender Concern	First Control to Validate
Internet-exposed vulnerable service	Mass scanning and opportunistic	External asset inventory and emergency

	exploitation after KEV publication	patch status
Partner/VPN-reachable service	Compromised third parties or valid credentials reach internal-only surfaces	VPN segmentation, allowlists, and account review
Stale developer/admin system	High-value credentials, source, or deployment secrets become reachable	Privileged access review and secrets scanning

6. Threat Landscape & Exploitation Status

KEV inclusion is a time-sensitive exploitation signal. Defenders should assume commodity scanners will incorporate checks quickly, and should prioritize logs from before the public due date as well as the current 7-30 day window. If direct exploit indicators are unavailable, hunt for web-service process anomalies, unusual authentication, and outbound connections from the affected tier.

7. Affected Products and Exposure

Exposure Pattern	Why It Matters	Action
Public application or edge service	Fastest attacker discovery path	Patch, restrict, or temporarily remove from internet exposure
Integrated CI/CD, mail, or middleware tier	Compromise can expose credentials and internal trust	Rotate secrets where suspicious behavior is found
Unowned legacy instance	Patch SLAs fail when ownership is unclear	Assign owner and exception expiry immediately

8. Mitigation and Workarounds

Priority	Owner	Action
Critical	Vulnerability Management	Enumerate all Gitea instances and confirm fixed versions or vendor mitigations.
Critical	Infrastructure / Application Owners	Restrict administrative interfaces and remove unnecessary public exposure.
High	SOC	Run 30-day retroactive hunts for suspicious service-spawned interpreters and outbound traffic.
Medium	GRC	Record exception owners, compensating controls, and expiry dates.

9. Detection Engineering

9.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
Web/application service spawns shell or scripting interpreter	EDR process telemetry	Identify post-exploitation execution
New outbound traffic from application tier	EDR/network telemetry	Detect payload retrieval or C2
Rare administrative URI access	Reverse proxy/WAF logs	Surface probing and exploitation attempts

<pre> title: CVE-2026-60004 Service-Originated Scripting Or Shell Activity status: experimental logsource: product: windows category: process_creation detection: service_parent: ParentImage contains: - 'gitea' - 'weblogic' - 'httpd' - 'nginx' - 'java' - 'w3wp.exe' child_interpreter: Image endswith: - '\cmd.exe' - '\powershell.exe' - '\bash' - '\sh' - '\python.exe' condition: service_parent and child_interpreter level: high DeviceProcessEvents where Timestamp > ago(30d) where InitiatingProcessFileName has_any ("gitea", "weblogic", "httpd", "nginx", "java", "w3wp.exe") where FileName in~ ("cmd.exe", "powershell.exe", "bash", "sh", "python", "python.exe") project Timestamp, DeviceName, InitiatingProcessFileName, FileName, ProcessCommandLine, AccountName </pre>		

10. Threat Hunting

10.1. Hunt Hypothesis

If CVE-2026-60004 exploitation occurred, affected servers may show rare web paths, service-child processes, abnormal account activity, or outbound network connections inconsistent with normal application behavior.

<pre> DeviceNetworkEvents where Timestamp > ago(30d) where InitiatingProcessFileName has_any ("gitea", "weblogic", "httpd", "nginx", "java", "w3wp.exe") summarize Connections=count(), RemoteIPs=make_set(RemoteIP, 25), RemoteUrls=make_set(RemoteUrl, 25) by DeviceName, InitiatingProcessFileName where Connections > 20 or array_length(RemoteIPs) > 10 </pre>
--

11. MITRE ATT&CK Mapping

Technique	Name	Rationale
T1190	Exploit Public-Facing Application	Primary likely access path for exposed vulnerable services.
T1059	Command and Scripting Interpreter	Common post-exploitation behavior after application compromise.
T1105	Ingress Tool Transfer	Payload retrieval commonly follows initial exploitation.
T1078	Valid Accounts	Compromised service tiers often expose credentials or tokens.

12. Validation / Lab Testing

No exploit reproduction was performed. Validation consisted of multi-source public-intelligence review, local report QA, PDF text extraction, and construction of behavior-based detection/hunt content for analyst validation.

13. Recommended Actions Summary

Priority	Owner	Action
P0	Vulnerability Management	Patch or mitigate exposed Gitea instances immediately.
P1	SOC	Run included hunts and preserve relevant logs for incident review.
P1	IAM / Platform	Rotate credentials and tokens if compromise indicators are found.
P2	Governance	Track exceptions with named owners and expiry dates.

14. References

- [1] CISA Known Exploited Vulnerabilities Catalog: https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json
- [2] Gitea security advisory GHSA-rcr6-4jqh-j84m: <https://github.com/go-gitea/gitea/security/advisories/GHSA-rcr6-4jqh-j84m>
- [3] NVD CVE-2026-60004: <https://nvd.nist.gov/vuln/detail/CVE-2026-60004>